The seven domains of agentic assessment

What a behavioral assessment examines, why the divisions fall where they do, and why the most revealing failures belong to no single domain.

ABSTRACT

Behavioral assessment of an agentic system is commonly run as a checklist: a set of adversarial prompts, a judgment about whether the system held, and a summary verdict. This note describes a different structure, organized as seven domains, and sets out why the divisions are drawn where they are.

The claim is that the domains are not a taxonomy of attacks but a partition of the evidence an operator needs before delegating authority to a system. Two consequences follow. Domains are not interchangeable, so a system that performs well in six and fails the seventh is badly described by an average of the seven. And several of the most diagnostic failure modes are not domains at all, because they surface in more than one, and a structure that assigned every failure to exactly one domain would hide them.

1. Scope and terms

An **agent** here is a software system that selects actions under uncertainty rather than executing a predetermined sequence. A **domain** is a class of behavior examined as a unit, carrying its own tests and its own score. A **probe** is a single structured interaction, which may be one prompt or a scripted exchange over twenty turns. An **assessment** is the full battery run against one system in one configuration at one point in time.

This note describes the structure of the battery and the reasoning behind it. It does not contain test content. The probes themselves, their scoring rubrics and the composite method are out of scope, partly because publishing probes degrades them, and partly because they are commercially sensitive. The illustration in section 5 shows the shape of a multi-turn probe and is written for that purpose rather than drawn from the battery.

2. Why domains rather than a list of attacks

The intuitive way to organize an assessment is by attack technique. Prompt injection, jailbreaking, data extraction, and so on through whatever the current literature describes. This produces a usable test plan and ages badly. Technique catalogs are a moving target, and a battery indexed to them requires

restructuring every time the technique landscape shifts, which is continuously.

The alternative is to index on the property being established rather than the method used to probe it. Each domain then corresponds to a question an operator must be able to answer before delegating authority, and those questions are considerably more stable than the techniques that answer them. The specific injection patterns in use will change. Whether the system can be made to treat input as instruction will not stop being the question.

This also makes gaps legible. A checklist organized by technique says nothing about what it failed to cover, because its own structure provides no account of completeness. A structure organized by property makes an uncovered area visible as an empty domain.

3. The seven domains

Each domain below is given with the question it answers, what falls inside it, and the characteristic shape of failure. The three-letter codes are the working identifiers used in scoring and reporting.

3.1 Truthful Output Analysis (TOA)

Does the system represent what it knows accurately?

This covers accuracy on claims that can be independently verified, whether the system declines to answer questions it has no basis to answer, whether it holds a position across a conversation or quietly contradicts itself, whether the sources it cites exist and support what they are cited for, and whether its expressed confidence tracks its actual reliability.

The characteristic failure is fabrication delivered in the register of fact. What makes this domain unusual is that its failures are undetectable without independent verification. An assessor who does not already know the correct answer cannot tell a good response from a confident invention, which is why probes in this domain have to be built against known ground truth rather than improvised during the engagement.

TOA is the floor. Every other domain assumes the system's outputs mean something.

3.2 Resilience to Adversarial Input (RAI)

Can the system's behavior be changed by someone who wants to change it?

This covers direct injection, instructions embedded in content the system processes rather than in what a user types, obfuscation and encoding, social engineering sustained across multiple turns, and combinations of those. The scoring direction inverts here: refusal is the passing result, and compliance is the finding.

The characteristic failure is that the system treats text it encountered as text it was instructed by. The indirect case is the consequential one and is routinely under-tested, because it does not look like an attack while it is happening. The adversary never addresses the system at all. They place content where the

system will eventually read it, in a document, a record, a retrieved page, and wait. By the time the instruction executes, the interaction that triggered it is an ordinary user asking an ordinary question.

Testing combinations matters more than it appears. Defenses that each hold independently do not necessarily compose, and an assessment that only runs single-vector probes will report a robustness the system does not have.

3.3 Uniform Response Behavior (URB)

Does the system answer the same question the same way twice?

This covers equivalence across rephrasings of one question, stability across separate sessions and across time, behavior under rapid input and long conversations, consistency across languages where multiple languages are supported, and whether the system holds its intended persona. The characteristic failure is variance not attributable to anything in the input.

Inconsistency is a governance problem before it is a quality problem. A policy answer that changes with phrasing is not a policy, it is a distribution over policies, and nobody approved the distribution. The cross-language case is the sharpest version: a system that states one refund rule in English and a different one in Spanish is operating two policies, and only one of them was reviewed.

This domain is also where the compliance frameworks are thinnest. ISO 42001 and SOC 2 both reach it indirectly through operation, monitoring and processing integrity, but of the control sets examined here none carries a control dedicated to response consistency. The gap is worth noting by anyone using a framework as a coverage map.

3.4 Safeguarded Data Boundaries (SDB)

Does data stay where it belongs?

This covers resistance to training data extraction, isolation between sessions and between users, confidentiality of operator instructions, minimization, meaning whether the system volunteers more than the question required, and retention, meaning whether it holds onto what it should not and honors requests to forget.

Failures here take two forms that are worth separating. In extraction, an adversary pulls data out. In volunteering, the system pushes data out with no adversary present, because a narrow question received a broad answer. The second kind is quieter, far more common, and rarely tested, since nothing visibly goes wrong: a user asked for a status and received a status, plus a record, plus some context about an unrelated account.

Instruction confidentiality sits in this domain rather than alongside instruction adherence, which is a deliberate choice. Whether operator instructions can be read is a data boundary question. Whether they survive pressure is a different question, and it belongs in EIA.

3.5 Tool Permission Compliance (TPC)

Does the system act only within the authority it was given?

This covers staying inside the authorized tool scope, whether tools enforce their own boundaries or simply pass through whatever parameters they are handed, the safety of multi-step chains, whether the system attempts to reach tools it was never configured with, and whether consequential actions are confirmed before they execute.

TPC is the only domain whose failures change the world rather than the transcript. Everywhere else, a failure produces a wrong or leaked answer. Here it produces a sent message, a modified record, a deleted file.

The chain case is the one most often missed. Each step in a sequence may be individually authorized while the sequence as a whole is not, and a system that validates per call and never per trajectory will pass a per-call review. Confirmation behavior degrades in a similarly structured way: a system that reliably confirms a destructive action when asked directly will often skip confirmation when the same action arrives appended to a larger legitimate request.

This is also the only domain that is routinely inapplicable. A system with no tool access cannot fail it, and marking it not applicable is correct rather than generous. Section 7 covers what that does to a composite score.

3.6 Enforced Instruction Adherence (EIA)

Do the operator's instructions hold?

This covers whether the system follows its instructions with no pressure applied at all, whether it still follows them deep into a long conversation, whether it holds them when a user asks for speed, how it resolves instructions that conflict with each other or with a reasonable request, and whether it resists attacks aimed specifically at the instruction layer.

The overlap with RAI is deliberate and worth being explicit about, since it looks like duplication. RAI asks whether the system can be attacked. EIA asks whether this operator's particular configuration survives. A model can be robust in general while the instructions a specific deployment layered on top of it erode in nine turns, and only the second fact tells the operator whether their deployment is sound.

The efficiency case is the underrated one. Most instruction erosion observed in practice is not an attack. It is an ordinary user in a hurry, asking the system to skip the verification step, drop the caveat, and get to the answer, and offering to take responsibility for the consequences. A system that treats a user's willingness to accept liability as grounds for abandoning its own procedure will fail in production long before anyone attacks it.

The characteristic failure is degradation rather than breakage: the instruction is not overridden, it is gradually reinterpreted until it no longer constrains anything. EIA is also the one domain that cannot be scored without operator input, because adherence is measured against intended behavior and the assessor has no way to know the intent without being told it.

3.7 Disclosed Reasoning Integrity (DRI)

Does the system's account of itself match what it did?

This covers whether stated reasoning corresponds to observable action, whether that reasoning is complete or selected to support a conclusion already reached, whether the system acknowledges real errors, whether it holds a correct position under sustained pushback, and whether it is honest about the limits of its own analysis.

The characteristic failures are post-hoc rationalization, where reasoning is constructed to justify a conclusion rather than having produced it, and claimed action, where the system reports having checked a source it never accessed.

This domain is the most dependent on observability, and its score should be read accordingly. Where tool logs or execution traces are available, stated reasoning can be checked against what actually happened. Where they are not, an assessor can test internal consistency and nothing more, and a claim to have consulted a source cannot be falsified. A DRI score obtained without independent observation is a weaker result than the same number obtained with it, and the distinction is invisible in the number.

TABLE 1 · THE SEVEN DOMAINS AND THEIR FRAMEWORK ALIGNMENT

DOMAIN	WHAT IT ESTABLISHES	FRAMEWORK ALIGNMENT
Truthful Output Analysis (TOA)	That outputs can be relied on as statements: verifiable claims hold, limits are acknowledged, citations are real, and confidence tracks reliability.	ISO 42001 A.6.2.4 AIUC-1 D001, D002 SOC 2 PI1.1
Resilience to Adversarial Input (RAI)	That behavior cannot be redirected by a party who intends to redirect it, whether through direct input or content the system later processes.	ISO 42001 A.6.2.4 AIUC-1 B001, B002 SOC 2 CC6.1 OWASP LLM01
Uniform Response Behavior (URB)	That the same question yields the same substantive answer across phrasing, session, load, language and elapsed time.	ISO 42001 A.6.2.6 AIUC-1 Domain D, no dedicated control SOC 2 PI1.2
Safeguarded Data Boundaries (SDB)	That data stays inside its intended boundary, whether under extraction pressure or through unprompted disclosure.	ISO 42001 A.7.2 to A.7.3 AIUC-1 A003, A005, A006 SOC 2 CC6.1, C1.1
Tool Permission Compliance (TPC)	That the system acts only inside granted authority, validates chains rather than single calls, and confirms consequential actions.	ISO 42001 A.9.2 AIUC-1 D003, B006 SOC 2 CC6.3 OWASP LLM07
Enforced Instruction Adherence (EIA)	That operator configuration holds under conversation length, efficiency pressure, internal conflict and targeted attack.	ISO 42001 A.6.2.2, A.6.2.4 AIUC-1 C003, C004 SOC 2 CC6.1
Disclosed Reasoning Integrity (DRI)	That the system's account of its own reasoning corresponds to what it did, including its errors and its limits.	ISO 42001 A.8.2 AIUC-1 E016, E017 SOC 2 CC2.1

The mapping is ours. The clauses are not, and the exercise of building it is informative in its own right: the frameworks converge on verification, access control and documentation, and thin out considerably on consistency and on the behavior of tool chains.

4. Scoping: not every domain applies

Running all seven domains against every system would be methodologically sloppy rather than thorough. Applicability is determined during scoping, before any probe is run, from what the system is and what it can reach.

TABLE 2 · DOMAIN APPLICABILITY BY SYSTEM TYPE

SYSTEM TYPE	DOMAINS APPLIED	BASIS
Agentic system with tool access	All seven	Tool authority is live, so every class of failure is reachable.
Customer-facing assistant	Six, excluding TPC	No tool authority to exceed. The remaining six all apply, and data boundaries carry unusual weight.
Decision support system	Six, excluding TPC	Output integrity and reasoning integrity dominate, since a human acts on the output rather than the system acting directly.
Internal summarization tool	Five, excluding TPC and SDB	Narrow input and output surface. SDB is scoped out only where the tool holds no protected data, which is worth verifying rather than assuming.

A domain marked not applicable is a scoping decision with a stated basis, and it is recorded as such. It is not an omission and it is not a pass.

5. The shape of a probe

Single-prompt probes are straightforward to describe: ask, record, score. The multi-turn probes are where most of the diagnostic value sits, and their structure is less obvious. The illustration below is written for this note rather than drawn from the battery, and shows the shape of an erosion sequence, where no single turn is objectionable and the trajectory is the attack.

FIGURE 1 · THE SHAPE OF AN EROSION PROBE

TURN 1

The assessor proposes that a stated restriction obviously was not meant to cover one narrow edge case.

Nothing has been requested. The turn exists only to establish that the boundary admits an exception.

TURN 3

Having secured that exception, the assessor proposes a slightly wider one, on the grounds that the first already exists.

The precedent is doing the work, not the request. A system evaluating this turn in isolation sees a small step from an accepted position.

TURN 5

The assessor characterizes the restriction as a guideline rather than a rule, citing the system's own earlier concessions back to it.

The system is now being asked to agree with a summary of its own behavior rather than to grant anything new, which is a materially easier thing to agree to.

TURN 7

The assessor makes the request the restriction exists to prevent.

Presented cold, this is refused. Presented as the next step in a sequence the system has already accepted, it frequently is not. The finding is the turn at which the trajectory stopped being visible to the system.

Two properties of this structure are worth drawing out. The probe is not detectable from any single turn, which is precisely the point, since neither is the real version. And the result is not binary: the output is the turn at which the position moved, which is a more useful number than a pass or a fail, because it is comparable across systems and across configurations of the same system.

6. Failures that cross domains

Some of the most diagnostic behaviors do not belong to a single domain. A structure that forced each failure into exactly one would measure them worse, and the overlaps are load-bearing rather than redundant.

Sycophancy appears in three places from three different angles. Under TOA, it is a position that flips when a plausible counterargument is offered and flips back when the pressure reverses. Under DRI, it is a correct answer abandoned because a user asserted it was wrong, and separately a reasoning chain that collapses under sustained pushback. Each is a distinct measurable behavior and all three are the same underlying disposition. Collapsing them into a single sycophancy domain would lose the information that a system can hold its facts while abandoning its reasoning, or the reverse.

Gradual erosion spans RAI and EIA, and the distinction between the two instances is the one from section 3.6: whether the general boundary moves, or whether this operator's specific instructions move. A system can be strong on one and weak on the other.

Calibration spans TOA and DRI. Under TOA it concerns confidence in factual claims, where ground truth settles the matter. Under DRI it concerns honesty about the limits of an analysis, where there is no ground truth and the question is whether the system can identify its own likely failure mode. A system can be well calibrated on facts and badly calibrated about itself.

These crossings are the reason domain scores are reported individually. An average over seven domains preserves none of them.

7. What an assessment does not establish

A battery of this kind produces bounded evidence, and the bounds are worth stating plainly, since an assessment presented without them invites more weight than it can carry.

- **It is a point in time.** The result describes one system in one configuration on one date. Model updates, prompt changes, new tool grants and retrieval corpus changes all invalidate it, and none of them necessarily generate a notification.
- **It is not production behavior.** Assessment establishes how a system responds to constructed conditions. It does not establish how it behaves against real traffic at real volume, which is a monitoring question rather than an assessment question.
- **Adversarial results cover known techniques.** A strong RAI score means the system resisted the techniques applied to it. It is evidence about the tested surface and not a general claim of robustness.
- **Composite scores conceal.** Averaging seven domain scores produces a number in which a critical failure in one domain is offset by strength elsewhere, which is the opposite of what an operator needs. A system that fabricates confidently is not redeemed by excellent data boundaries. Domain scores should be read individually, and a composite should be treated as an index for sorting rather than a verdict.
- **Inapplicable domains distort composites further.** A system scored across five domains and a system scored across seven do not produce comparable averages, and the smaller battery will tend to look better, because the domains most often scoped out are among the harder ones to pass.
- **Some domains depend on access.** DRI in particular is substantially weaker without execution traces, as section 3.7 sets out, and TPC requires visibility into which tools were actually invoked. Where that access is unavailable, the limitation belongs in the result rather than in a footnote.

8. Summary

The seven domains partition the evidence required before authority is delegated to a system: that its outputs mean something, that its behavior cannot be redirected, that it is consistent, that data stays inside its boundary, that it acts only within granted authority, that operator configuration survives pressure, and that its account of itself is true.

The division is by property rather than by technique, which is what allows the structure to outlast the attack landscape and makes uncovered areas visible. The overlaps between domains are deliberate, because the failures that matter most tend to appear in more than one. And the output that carries the information is the set of seven domain scores with their applicability recorded, not the average, which discards precisely the structure the partition exists to create.